Ironbridge National Bank – Incident Response Plan

1. Purpose and scope

This plan tells the Ironbridge National Bank security team exactly how to detect, contain, and recover from a security incident, and who does what. It is written so a new analyst can pick it up and act without asking anyone first. It satisfies PCI DSS Requirement 12.10.

An **incident** is any event that threatens the confidentiality, integrity, or availability of bank systems or data. Examples: malware running on a server, an admin account used by someone other than its owner, customer records copied out, or a service taken offline.

Systems in scope

System	Role	Owner	Key data / risk
vm-team4-dc (10.10.60.196)	Domain controller, DNS, Ironbridge Root CA, file server	Dominic Yeakel	All domain accounts, Kerberos keys, CA private key
\vm-team4-dc\BankData	File share	Dominic Yeakel	Customer and transaction records
vm-team4-dvwa.ironbridge.local	Public-facing web application (DVWA)	Jason Man	Web server, application database
Azure Bastion (10.10.40.0/26)	Only management path into the VMs	Instructor / Azure admin	Administrative access

Out of scope: the Azure platform itself and the instructor's shared infrastructure.

Data note: all customer and transaction data in this environment is synthetic (IDs start with `SYN-`). Handle it as if it were real customer data; the plan is judged on the process, not the data's value.

2. Roles and responsibilities

Every incident has one Incident Commander who makes the decisions; everyone else reports to them. With a two-person team, each person holds two roles, and remediation goes to whoever owns the affected system.

Role	Primary	Responsible for
Incident Commander (IC)	Jason Man (jm-admin)	Declares the incident and severity, assigns tasks, approves containment and recovery, keeps the incident log, briefs leadership, approves every external notification, decides when to close

Role	Primary	Responsible for
Remediation Specialist	Dominic Yeakel (dy-admin)	Executes the containment, eradication, and recovery steps the IC approves on every system: vm-team4-dc, BankData, and DVWA
SOC Tier 1	Nathan	Performs first triage, opens the incident record, escalates to SOC Tier 3 and the IC
SOC Tier 3	Carter	Leads deep investigation and threat hunting in Sysmon, determines scope and indicators, tunes detections afterward
Forensics Analyst	Jack	Collects and preserves evidence, maintains chain of custody, builds the timeline, determines root cause
IT Operations	Ryan	Keeps services running, coordinates snapshots, restores, and network changes with the instructor and Azure administrator, supports account resets
GRC	Carin	Tracks regulatory and PCI DSS obligations, runs the 36-hour OCC clock, drafts regulator and customer notices for IC approval, keeps records for audit and the post-incident review
TPRM	Dennis	Handles third-party involvement (Azure, card processors, other service providers): vendor notifications, contract obligations, and service-provider incident notices

Escalation inside the team: SOC Tier 1 triages and hands confirmed or unclear alerts to SOC Tier 3, who brings in the IC. The IC then engages the Remediation Specialist, Forensics Analyst, and the other roles the incident needs.

Rules that apply to every role

- Volunteer roles should be filled day of before the attack
- Only the IC approves actions that cause downtime, delete data, or reset accounts.
- The Forensics Analyst collects and hashes evidence before the Remediation Specialist cleans any system (section 7).
- Use your named admin account (dy-admin or jm-admin). Use the break-glass account (azureadmin) only if the named accounts are locked out or compromised, and log every use.

Open item: add each volunteer's name to this table, IC should share their screen so others can see what is happening.

3. Severity levels

Assign a severity as soon as an incident is declared, and re-rate it whenever new facts arrive. When unsure between two levels, choose the higher one.

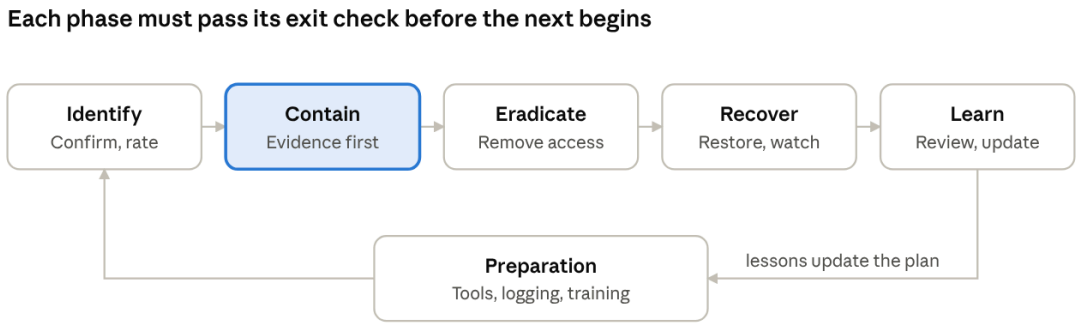
Level	Definition	Examples in this environment	Engage IC	Contain within	Triggers
SEV1 Critical	Bank-wide impact, confirmed compromise of identity or customer data	Domain admin account used by an attacker; ransomware encrypting BankData; customer records copied out; CA private key stolen; LSASS dump on the DC	15 min	1 hour	Both team members full-time; leadership briefed within 1 hour, then every 2 hours; regulator notification assessment starts (section 5); evidence preserved before any cleanup
SEV2 High	Confirmed compromise of one system, no confirmed data loss yet	Web shell or command injection on DVWA; malware executed on a server; one named admin account compromised; Defender or Sysmon disabled without a change record	30 min	4 hours	Both team members engaged; leadership briefed within 4 hours; escalate to SEV1 if data access is confirmed
SEV3 Medium	Attack attempted or partly blocked, no confirmed compromise	Defender quarantined malware; password spraying	4 hours	1 business day	One analyst investigates; IC reviews findings; noted

Level	Definition	Examples in this environment	Engage IC	Contain within	Triggers
		causing lockouts; honeytoken account login attempt; ASR rule blocks			in weekly summary
SEV4 Low	Suspicious but likely benign, or a policy issue	Port scan from outside; single failed logon; misconfiguration found in review	Next business day	As scheduled	Logged and tracked; no leadership briefing

All times are measured from when the incident is declared and recorded in UTC in the incident log.

4. Incident lifecycle

The plan follows the NIST SP 800-61 phases: identify, contain, eradicate, recover, and learn. Each phase ends with an exit check; do not move on until it passes. Run Windows commands in an elevated PowerShell window on vm-team4-dc, and record every action with a UTC time in the incident log.



Containment is highlighted because it is where evidence is most often lost: collect volatile evidence before containing.

4.1 Preparation (already in place)

- **Detection sources:** Initial triage detection script, Microsoft Defender (real-time, cloud, 13 ASR rules), Sysmon (sysmon-modular config), PowerShell script block logging and transcripts (C:\PSTranscripts), Security auditing (logon, account management, privilege use, object access), firewall logging of blocked connections.

- **Protections:** LSA Protection on LSASS, least-privilege groups on BankData, management access only through Azure Bastion, SMB signing required, SMB1 removed.
- **Known gaps:** Defender Tamper Protection is off; there is no backup or snapshot capability without the instructor.

4.2 Identify

Goal: confirm whether something is an incident, how bad it is, and what it touches.

First check: run the triage script. Any domain admin can run it on vm-team4-dc in an elevated PowerShell window. The first line confirms the script has not been altered:

$s = 'C:\IR\Scripts\Invoke-IronbridgeTriage.ps1'

if ((Get-FileHash s). Hash - eq(Get - Content"s.sha256")) { 'Script verified' } else { 'WARNING: script modified - tell the IC' }

Set-ExecutionPolicy Bypass -Scope Process -Force

& $s # last 24 hours; add -Hours 4 for a shorter window

The script is read-only and takes a few minutes. Each check prints ALERT (act now), REVIEW (explain it), or OK, and the run ends with either START WITH PLAYBOOK N plus its starting severity and lead, or CHECK THE WEB SERVER NEXT if the DC is clean. It saves a report and its SHA-256 hash to `C:\IR\Triage`; copy both into the incident's evidence folder. Treat the recommendation as a starting point and confirm it with the host checks below and the playbook's Decision Point. It compares the server against the baseline in `C:\IR\Baseline`, which is re-saved (`-SaveBaseline`) only after approved changes, and only dy-admin can modify the script.

1. Record the alert or report: time, who found it, what they saw.
2. Check the hosts directly. On the DC, in an elevated window, run `Get-MpThreatDetection` and the `Get-WinEvent` checks below; add `StartTime=(Get-Date).AddHours(-24)` inside the braces to narrow the window.
    - Defender detections: `Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Windows Defender/Operational'; Id=1116,1117}`
    - Failed logons (spraying, brute force): `Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625}`
    - Admin group changes: `Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4728,4732,4756}`
    - Recent processes: `Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Sysmon/Operational'; Id=1}`
    - Access to LSASS: `Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Sysmon/Operational'; Id=10} | Where-Object Message -match 'lsass.exe'`

    - Decoded PowerShell: `Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-PowerShell/Operational'; Id=4104}`
    - Defender settings changed: `Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Windows Defender/Operational'; Id=5001,5007}`
    - DVWA web attacks: the SOC Tier 3 analyst reads `/var/log/apache2/access.log` and `error.log` and looks for injection strings, unexpected uploads, and requests to new files in the web root.
3. Decide: if it is an incident, the IC declares it, assigns an ID (`INC-YYYYMMDD-NN`), sets a severity (section 3), and creates the evidence folder `C:\IR\INC-YYYYMMDD-NN\`.

Exit check: incident declared, severity set, affected systems and accounts listed.

4.3 Contain

Goal: stop the damage from spreading without destroying evidence. Collect volatile evidence first (section 7, steps 1 to 3), then contain.

Situation	Action
Account compromised	`Disable-ADAccount <user>`; reset its password; close its sessions with `Get-SmbSession -ClientUserName *<user>* | Close-SmbSession -Force`
Attacker IP identified	`New-NetFirewallRule -DisplayName "IR-Block-<IP>" -Direction Inbound -RemoteAddress <IP> -Action Block`, plus the same rule with `-Direction Outbound`
Malicious process running	Note PID, path, and hash first; then `Stop-Process -Id <PID> -Force`
BankData being encrypted or copied	Block the account on the share: `Block-SmbShareAccess -Name BankData -AccountName <user> -Force`
DVWA compromised	`sudo systemctl stop apache2` and `sudo ufw deny from <IP>`; keep the VM running so memory and files are preserved
Domain-wide compromise (SEV1)	IC requests isolation of the affected VM's network from the instructor; do not shut down the DC without IC approval, since it runs DNS and authentication for everything

Exit check: attacker activity has stopped (no new related events for 30 minutes), and evidence collection is complete.

4.4 Eradicate

Goal: remove every trace of the attacker's access.

1. Remove malware: `Start-MpScan -ScanType FullScan`, then `Remove-MpThreat`.
2. Find and remove persistence: new services (Security 4697, System 7045), scheduled tasks (4698), Run keys (Sysmon 12/13), WMI subscriptions (Sysmon 19 to 21), unknown accounts or group memberships.
3. Reset every credential the attacker could have seen. If a Domain Admin account or the DC itself was compromised, reset the `krbtgt` password twice, at least 10 hours apart, to invalidate forged Kerberos tickets.
4. If the CA was compromised, revoke all certificates issued since the compromise and treat the CA as untrusted until rebuilt.
5. For DVWA, rebuild the web root from a known-good copy rather than cleaning files one by one.
6. Fix the root cause (patch, close the port, remove the excess permission).

Exit check: full Defender scan clean, no unknown persistence, root cause fixed.

4.5 Recover

Goal: return to normal service and prove the attacker is gone.

1. Restore affected data from the last known-good copy (see the backup gap in 4.1; the instructor holds snapshot capability).
2. Re-enable services and accounts one at a time, with IC approval.
3. Re-run the vulnerability scan and compare it to the baseline from 2026-10-05.
4. Watch the affected systems closely for 72 hours: rerun the triage script and review the Defender, Sysmon, and Security logs for the affected hosts and accounts daily.

Exit check: services restored, scan matches baseline, 72 hours with no recurrence. The IC closes the incident.

4.6 Lessons learned

Hold a post-incident review within 5 business days of closing (section 9). Record the root cause, what worked, what did not, the MTTD and MTTR (section 10), and the action items with owners. Update this plan and the affected playbook.

5. Escalation path

The Incident Commander owns every notification decision; Stakeholder Communications drafts and sends once the IC approves. The hardest deadline is regulatory: as a national bank, Ironbridge must notify the OCC as soon as possible and no later than 36 hours after determining that a notification incident has occurred (OCC Bulletin 2021-55). A notification incident is one that has materially disrupted, or is reasonably likely to disrupt, the bank's operations or its ability to serve customers.

Who	When	Trigger	Notified by	How
Incident Commander	Within the severity's engage time (section 3)	Any declared incident	Whoever detected it	Phone or chat, then the incident log
Bank leadership (CIO / CISO)	SEV1: 1 hour; SEV2: 4 hours; SEV3: weekly summary	Severity set	Stakeholder Communications	Briefing (section 6)
Legal and Compliance (incl. BSA Officer)	SEV1 and SEV2, at declaration	Customer data, fraud, or regulatory exposure possible	Incident Commander	Phone, then written summary
OCC (primary federal regulator)	As soon as possible, no later than 36 hours after determination	Incident is a notification incident	Compliance, with IC input	Per OCC instructions
Law enforcement	SEV1, after Legal approves	Criminal activity such as ransomware or theft	Legal, with IC	Phone and IC3 report
Card brands and acquiring bank	As soon as compromise of cardholder data is suspected	Possible cardholder data exposure (PCI DSS)	Compliance	Per acquirer agreement
Affected customers	After scope is confirmed and Legal approves	Unauthorized access to sensitive customer information where misuse is reasonably possible (GLBA)	Stakeholder Communications, approved by Legal	Letter or email using an approved template
Cyber insurer	SEV1, at declaration	Per policy terms	Legal	Per policy
Instructor / Azure administrator	Any time platform action is needed	Network isolation, disk snapshot, VM restore	Incident Commander	Class channel

Lab rule: in this course, every external notification (OCC, FBI, card brands, customers, insurer) is simulated. Record each simulated notice, with its time, in the incident log so the 36-hour clock can be checked.

6. Communication plan

Leadership gets short, plain-language updates on a fixed schedule: what happened, what it means for customers and the bank, and what we need from them. No jargon, no guesses stated as facts.

Cadence

Severity	First briefing	Updates	Final report
SEV1	Within 1 hour of declaration	Every 2 hours, and at every major change	Within 5 business days of closing
SEV2	Within 4 hours	Twice daily	Within 5 business days of closing
SEV3	Weekly summary	As needed	Included in monthly metrics
SEV4	Not briefed	None	Included in monthly metrics

Briefing template (during the incident)

```
Incident: INC-YYYYMMDD-NN | Severity: SEV_ | Status: Investigating / Contained /
Recovering / Closed
Time of this update (UTC):

What happened: one or two sentences, plain language.
What it affects: systems, services, and whether customer data is involved (yes / no /
not yet known).
What we have done: containment actions taken so far.
What happens next: next steps and when the next update will come.
What we need from you: decisions, approvals, or resources. "Nothing at this time" if
none.
Regulatory clock: notification incident? (yes / no / assessing), 36-hour deadline if
yes.
```

Rules for every message

- Say "we don't know yet" rather than guess; correct earlier statements openly if facts change.
- Translate technical terms: "an attacker gained the password of an administrator account," not "credential compromise via LSASS dump."
- Keep incident details on a need-to-know basis. Do not discuss the incident in shared channels, email threads with outside parties, or on the affected systems themselves, since the attacker may be watching them.
- Customer, regulator, and media statements go out only with Legal's approval.

After the incident: the final report covers the timeline, root cause, customer impact, notifications made, MTTD and MTTR, and the action items from the post-incident review, written for a non-technical reader.

7. Evidence handling

Evidence is collected before cleanup, hashed the moment it is collected, and copied off the affected host, so findings hold up in a regulatory exam or court. Collect the most volatile evidence first, because it disappears on reboot.

Windows (vm-team4-dc), elevated PowerShell

1. Create a protected evidence folder:

```
$ir = "C:\IR\INC-YYYYMMDD-NN"; New-Item $ir -ItemType Directory -Force |
Out-Null
icacls $ir /inheritance:r /grant:r "SYSTEM:(OI)(CI)F"
"BUILTIN\Administrators:(OI)(CI)F"
```

2. Capture volatile state (running processes, connections, sessions):

```
Get-CimInstance Win32_Process | Select ProcessId, ParentProcessId, Name,
CommandLine, CreationDate | Export-Csv "$ir\processes.csv" -NoTypeInformation
Get-NetTCPConnection | Select LocalAddress, LocalPort, RemoteAddress,
RemotePort, State, OwningProcess | Export-Csv "$ir\connections.csv"
-NoTypeInformation
Get-SmbSession | Export-Csv "$ir\smb-sessions.csv" -NoTypeInformation
query user > "$ir\logged-on-users.txt"
```

3. Export the event logs:

```
'Security','System','Microsoft-Windows-Sysmon/Operational','Microsoft-Windows-
PowerShell/Operational','Microsoft-Windows-Windows
Defender/Operational','Directory Service' |
  ForEach-Object { wevtutil epl $_ "$ir\$($_ -replace '[/ ]','_').evtx" }
Copy-Item C:\PSTranscripts "$ir\PSTranscripts" -Recurse
```

4. Hash everything and save the hash list:

```
Get-ChildItem $ir -Recurse -File | Get-FileHash -Algorithm SHA256 | Export-Csv
"$ir\hashes.csv" -NoTypeInformation
```

Linux (DVWA), partner

```
IR=/root/IR/INC-YYYYMMDD-NN; sudo mkdir -p $IR
sudo sh -c "ps auxf > $IR/processes.txt; ss -tunap > $IR/connections.txt; who >
$IR/users.txt"
sudo tar czf $IR/apache-logs.tgz /var/log/apache2 && sudo tar czf $IR/webroot.tgz
/var/www
sudo sh -c "sha256sum $IR/* > $IR/hashes.txt"
```

Disk images: request an Azure disk snapshot of each affected VM from the instructor before eradication begins. Record the snapshot name and time in the chain of custody.

Handling rules

- Work on copies, never the originals. Re-hash a copy before analysis and confirm it matches hashes.csv

- Copy the evidence folder off the host as soon as it is hashed (to another team member's machine), because an attacker with admin rights can delete it.
- Do not run unknown files outside an isolated analysis environment.
- Keep incident evidence and related logs for at least 12 months, matching PCI DSS log retention.

Chain of custody log (one row per transfer, kept in the evidence folder)

Date/time (UTC)	Item	SHA-256	Collected or transferred by	From	To	Purpose

8. Playbook index

Each playbook in Part C gives step-by-step actions for one incident type; this plan sets the rules every playbook follows. Start with the playbook that matches the first alert, and switch if the facts point elsewhere.

#	Playbook (Part C)	Typical first signal	Starting severity	PCI DSS
1	Phishing / Business Email Compromise	Spoofed sender, suspicious link or attachment, urgent credential or payment request, user reports clicking or entering credentials	SEV3; SEV2 if credentials were entered or abnormal logins follow	8, 12
2	Malware Infection	Defender alert, unknown process, unexpected service or scheduled task, unusual outbound connection, drift from the A2/A3/A4 baseline	SEV2	5, 6, 10
3	Ransomware	Many files changing rapidly on BankData, unexpected extensions, ransom note, one account modifying large numbers of files	SEV1	3, 5, 12.10
4	Distributed Denial of Service (DDoS)	Web traffic or connection counts well above baseline, rising HTTP errors, slow or unavailable web app	SEV2	1, 6, 10

#	Playbook (Part C)	Typical first signal	Starting severity	PCI DSS
5	Web Application Attack / Defacement	Unexpected site content, changed web-root files or hashes, unexpected uploads, suspicious HTTP requests	SEV2	6, 10, 11
6	Brute Force / Credential Stuffing	Repeated failed logons, many accounts targeted from one source, lockouts, a success after many failures	SEV3; SEV2 if a login succeeds after failures	8, 10
7	AI Deepfake-Enabled Fraudulent Transaction	Urgent payment request through an unusual channel, executive impersonation, pressure to skip verification	SEV2; SEV1 if funds were transferred	8, 12
8	Insider Threat	Access outside job role, unexpected admin or sudo use, unauthorized account or group changes, large file copies at odd hours	SEV2	7, 8, 10
9	Data Exfiltration	Large or unusual outbound transfers, new destinations, large reads from BankData tied to an external connection	SEV1	1, 3, 4, 10
10	Privilege Escalation / Lateral Movement	New admin or sudo account, privileged-group change, unexpected service or task, connections from vm-team4-dvwa (10.10.60.197) to vm-team4-dc (10.10.60.196)	SEV1	7, 8, 10

Playbook Link:
https://docs.google.com/document/d/1TnBQfyXcB0rU68qj4VnbCJBFLDXu96vLNm5NlMMSQjg/edit?usp=sharing

9. Testing, exercises, and reviews

The plan is tested at least once a year as PCI DSS 12.10.2 requires, and in this program every quarter, because an untested plan fails under pressure.

Activity	How often	Who	Output
Tabletop exercise	Quarterly, rotating through the ten playbooks	Both team members; instructor as leadership and regulator	Exercise report with gaps and action items
Technical drill	Twice a year	Both team members	Proof that detections fire and commands work (e.g. encoded PowerShell run as a test, EICAR file, evidence collection script)
Plan review and update	Annually, and after every SEV1/SEV2, tabletop, or major system change (new server, new tool, a new log source or detection rule)	Incident Commander	New version with a dated change history
Contact list check	Quarterly	Stakeholder Communications	Confirmed names and numbers for every row in section 5
Post-incident review	Within 5 business days of closing every SEV1 to SEV3	Both team members	Review record (below)

Running a tabletop (90 minutes)

1. Pick a scenario from one playbook and write 3 to 4 timed injects (for example: Defender alert, then a new Domain Admins member, then a leadership question about customer data).
2. Walk through each inject using only this plan and the playbook: who acts, what command, who is told, by when.
3. Time the regulatory decision: did the team decide on OCC notification within the 36-hour window?
4. Record every point where the plan was unclear, wrong, or missing a step.

Post-incident review record

- Timeline (UTC): first malicious activity, detection, declaration, containment, eradication, recovery, closure
- Root cause and how the attacker got in
- What worked and what did not
- MTTD and MTTR for this incident (section 10)
- Action items, each with an owner and due date

Reviews are blameless: they look for gaps in process and tooling, not people to fault.

10. Incident metrics and the dashboard

Every incident records five UTC timestamps in its log, and the dashboard's two headline numbers, mean time to detect (MTTD) and mean time to respond (MTTR), are calculated from them.

Timestamp	Meaning	Where it comes from
T0 – First malicious activity	Earliest attacker action found	Forensic timeline (Sysmon, Security, Apache logs)
T1 – Detected	First alert or report	Defender, Sysmon, or user report
T2 – Declared	IC declares the incident	Incident log
T3 – Contained	Attacker activity stopped	Incident log
T4 – Recovered	Service restored, incident closed	Incident log

The team also tracks mean time to contain (T3 minus T1), incidents per month by severity and playbook, the share of incidents found by our own tools versus reported by others, and how many post-incident action items are overdue.

How the numbers are calculated

1. When the IC closes an incident, they add one row to the incident register (ID, severity, playbook, T0 to T4, root cause).
2. The IC keeps the register as a shared spreadsheet and calculates MTTD, MTTR, and mean time to contain from it, by month and severity. For incidents raised by a Defender or Sysmon alert, T1 is the event's timestamp.
3. Leadership reviews these numbers monthly. A rising MTTD points to a detection gap (a new Sysmon rule or triage-script check is needed); a rising MTTR points to a response gap (a playbook or permission problem).

Incident register

Incident ID	Severity	Playbook	T0	T1	T2	T3	T4	Root cause

11. PCI DSS 12.10 mapping and quick start

This plan is the bank's response to PCI DSS Requirement 12.10; the table shows where each sub-requirement is met and what is still open.

PCI DSS v4.0	Requirement	Where met	Status
12.10.1	Incident response plan with roles, procedures, notifications, and recovery	Sections 2 to 8	Met; backup and restore capability is a known gap (4.1)
12.10.2	Plan reviewed, updated, and tested at least every 12 months	Section 9	Met by schedule; first tabletop not yet held
12.10.3	Specific personnel available 24/7 to respond	Section 2	Met
12.10.4	Response personnel trained	Section 9 (tabletops, drills)	Met by schedule
12.10.5	Security monitoring alerts feed the plan	Section 4.2 (Defender, Sysmon, PowerShell, and Security log monitoring plus the triage script)	Met
12.10.6	Plan updated from lessons learned and industry changes	Sections 4.6 and 9	Met
12.10.7	Procedures if stored card numbers are found where not expected	PB-06	Open: (BankData holds no card numbers today)